

ISO/IEC 27001 Information Security Management Standard Requirements Overview

Page 1 of 3 | Document ID: doc_en_02

Clause 4-6: Context of the Organization, Leadership, and Planning

ISO/IEC 27001 specifies requirements for establishing, implementing, maintaining, and continually improving an ISMS.

Top management must demonstrate leadership and commitment by ensuring the information security policy is established and

The risk assessment methodology must identify risks associated with the loss of confidentiality, integrity, and availability.

Risk treatment plans must systematically compare identified security controls against Annex A reference control objectives.

ISO/IEC 27001 Information Security Management Standard Requirements Overview

Page 2 of 3 | Document ID: doc_en_02

Clause 7-9: Support, Operational Control, and Performance Evaluation

Organizations must determine and provide necessary competent resources, awareness training, and documented information.

Operational planning requires implementing risk treatment actions and maintaining documented evidence of control execution.

Management must conduct formal ISMS reviews at planned intervals, at least annually, to ensure ongoing suitability and adequacy.

Internal audits must be scheduled and carried out objectively to verify adherence to ISMS requirements and policies.

ISO/IEC 27001 Information Security Management Standard Requirements Overview

Page 3 of 3 | Document ID: doc_en_02

Annex A Control Structure: The 93 Controls across Four Themes

Annex A organizes 93 controls into four distinct themes: Organizational (37 controls), People (8), Physical (14), and Technological (34).

A mandatory Statement of Applicability (SoA) must document which Annex A controls are selected and justify any control exclusions.

Control A.5.23 governs information security for use of cloud services, mandating formal processes for acquisition and management.

Control A.8.8 mandates technical vulnerability management through regular scanning, risk prioritization, and remediation timelines.